RAJALAKSHMI ENGINEERING COLLEGE

(An Autonomous Institution)

Rajalakshmi Nagar, Thandalam – 602 105

CR23532 – CYBER AND DIGITAL FORENSICS

MINI PROJECT

ASSIGNMENT II

CASE STUDIES 1 – 5

Name :	KRISHNA KUMAR J
Register Number :	241901505
Branch :	B.E. Computer Science and Engineering (Cyber Security)
Year / Semester :	III Year / V Semester
Faculty In-charge :	Dr. D. SIVAKUMAR
Academic Year :	2026 – 2027

CASE STUDY 1

INSIDER COMPROMISE OF AN ONLINE TALENT-HUNT SCORING PLATFORM ("THE RIGGED LEADERBOARD")

1. Introduction

Insider threats are among the hardest cases in digital forensics because the offender already holds legitimate access, so their actions look like normal activity. This case study investigates a manipulation of a competition scoring platform in which the person who reported the incident and led the internal inquiry is later shown to be responsible. It applies the standard forensic process (identification, preservation, collection, examination, analysis, reporting) and shows how corroborating independent evidence sources can attribute actions to an insider.

2. Scenario Background

The *BrightStar Online Talent Championship* is a national web-based coding and design contest. Participants submit entries, judges score them through an admin panel, and results appear on a public leaderboard. The platform runs on a Linux cloud server (Nginx web server, application backend, MySQL database).

On the evening of the finale (22 March 2026), the scores of four finalists were altered, and the leading team, "Team Nova," was flagged as disqualified for plagiarism. At 08:05 PM, the event director, **Meera Krishnan**, reported the incident to the sponsors, stating that an external hacker had compromised the platform. She offered to lead the internal investigation. Because of the conflict of interest, the sponsors appointed an independent digital forensic examiner to investigate.

3. Assumptions

1. All timestamps are in IST (UTC+5:30), and server clocks were NTP-synchronized (to be verified).
2. Logs were enabled before the incident and were not rotated or deleted.

3. A database backup snapshot from 04:00 PM on 22 March exists and predates the incident.
4. The admin panel supports individual user accounts, with a password and an OTP from a registered device.
5. Legal authorization to examine the server and the organizer's work laptop was obtained from the organizing company.
6. Names, IP addresses, and file names are fictional and used for illustration. Any outputs described are *expected* results of the procedure, not actual execution.

4. Objectives and Scope

- Determine whether the scores and disqualification flag were altered, and what exactly changed.
- Identify how, when, and from which account/device the changes were made.
- Evaluate the "external hacker" claim against the evidence.
- Preserve evidence in a form suitable for legal proceedings.

5. Parties Involved

Party	**Role**
Meera Krishnan	Event director; reporter of the incident
Four finalist teams (including Team Nova)	Affected participants
Sponsors' committee	Authorizing body
IT administrator	Provides server access and logs
Forensic examiner (you)	Independent investigator

6. Forensic Methodology

The investigation follows the standard digital forensic lifecycle:

1. **Identification:** list systems and data sources that may hold evidence.
2. **Preservation:** freeze changes to the server state, restrict access, and stop log rotation.
3. **Collection:** copy logs, database files, and the laptop image using verified methods.
4. **Examination:** extract relevant records and artifacts.
5. **Analysis:** correlate sources, build the timeline, and test hypotheses.
6. **Reporting:** document findings, methods, and limitations.

7. Evidence Identification

ID	Evidence Item	Source	Relevance
E1	Web server access logs	Nginx	Who accessed the admin endpoints, when, from where
E2	Application logs	Backend server	Actions taken inside the application
E3	Database binary log and audit table	MySQL	Exact UPDATE statements and timestamps
E4	Admin panel login and session records	Application database	Account, IP, device, and session of each login
E5	04:00 PM database backup	Backup storage	Baseline to compare against
E6	Organizer's work laptop (disk image)	Director's laptop	User activity, files, browser artifacts
E7	Incident report email with headers	Mail server	Origin, time, claims made

ID	Evidence Item	Source	Relevance
E8	Office access and VPN logs	Facility and network systems	Physical and remote presence

8. Evidence Acquisition and Chain of Custody

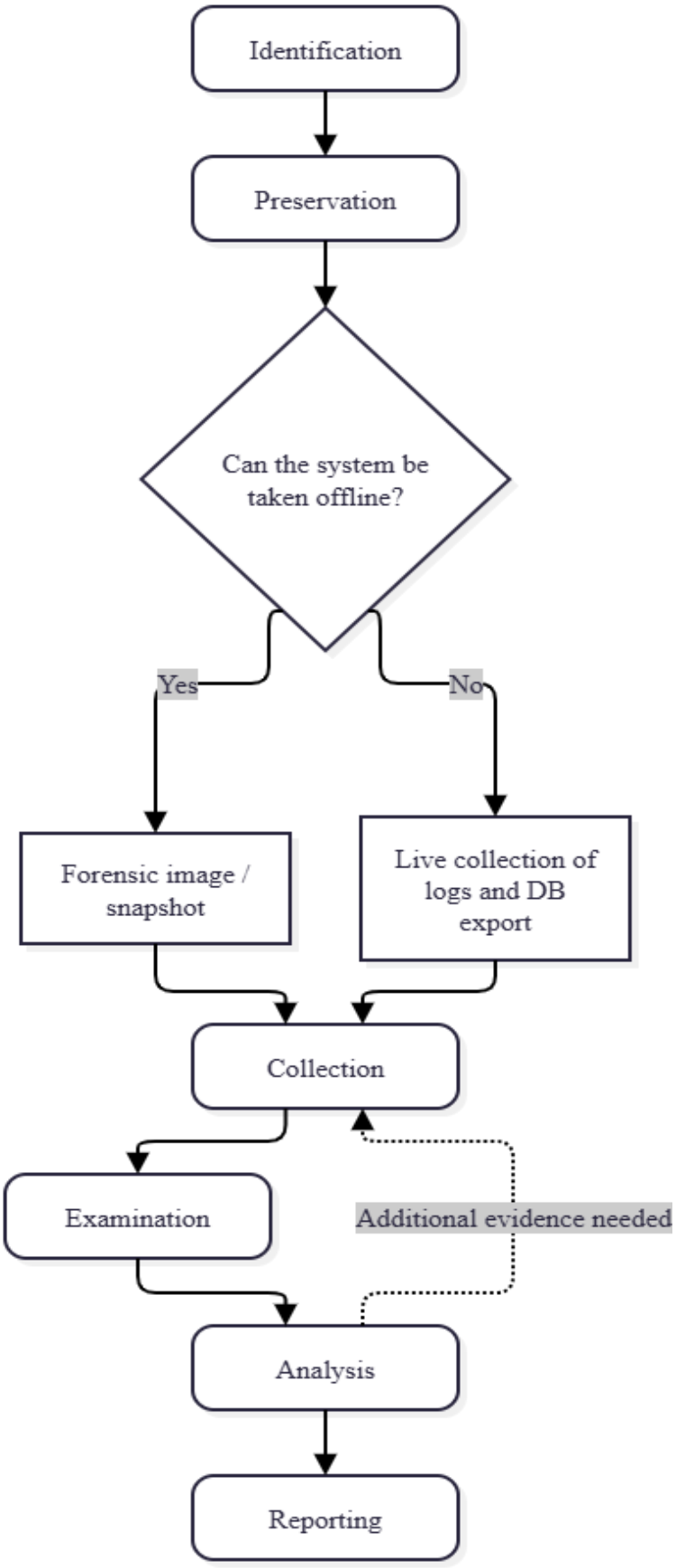
Procedure:

1. Take a snapshot of the cloud VM and export logs to a read-only location.
2. For the laptop, connect through a hardware write-blocker (or boot a forensic live environment) and create a forensic image with FTK Imager, producing an E01 image.
3. Compute a SHA-256 hash of every original item and every copy using sha256sum (or the imager's built-in verification). Matching hashes prove the copies are exact.
4. Work only on verified copies. Keep originals sealed.
5. Record every transfer on a custody form.

Sample chain of custody record:

Item ID	Description	Collected by	Date / Time	SHA-256	Transferred to	Purpose
E1	Nginx logs	Examiner	[date/time]	[record at collection]	Forensic lab	Access analysis
E3	MySQL binlog	Examiner	[date/time]	[record at collection]	Forensic lab	Change analysis
E6	Laptop image	Examiner	[date/time]	[record at collection]	Evidence locker	User activity

9. Forensic Process Flowchart



10. Examination and Analysis

10.1 Integrity verification: Recompute hashes of all working copies and compare them with the values recorded at collection. Any mismatch is documented and the copy is re-acquired.

10.2 Evidence analysis

Evidence	Procedure	Expected finding	Interpretation
Database (E3, E5)	Compare the 04:00 PM backup with the current data; read the binary log with mysqlbinlog	Four score rows changed and Team Nova's flag set manually, not by the plagiarism checker	Deliberate changes made through the admin function, not a direct database break-in
Web logs (E1)	Filter admin endpoint requests with grep/awk; extract IP, user-agent, status	All requests from one IP and browser, all successful (200)	No scanning or injection, so it does not match a typical external attack
Login and session records (E4, E2)	Match session IDs from the logs to the admin login table	Account director_meera logged in at 05:58 PM with a valid OTP; same session ID on every change	The account made the changes; credential theft alone is a weak explanation
Laptop image (E6)	Examine in Autopsy: browser history, recent files,	Admin panel open during the incident; a ranking file created	Suggests premeditation

Evidence	Procedure	Expected finding	Interpretation
	MACB timestamps, deleted files	earlier, with a related file later deleted	(circumstantial, read with the logs)
Incident email (E7)	Analyze email headers	Sent from her own account; “external attack” claim has no technical support	The narrative was not based on the logs

10.3 Timeline

Time (IST)	Event	Source
Earlier in week	Ranking file created on laptop	E6
04:00 PM	Clean backup taken	E5
05:58 PM	director_meera logs in with OTP	E4
06:10 PM	Four finalists’ scores updated	E3, E1
07:45 PM	Team Nova flagged as disqualified	E3, E2
08:05 PM	Incident reported, blaming an external hacker	E7
After 08:05 PM	Related file deleted from laptop	E6

Merge all sources into one timeline after normalizing time zones, using Plaso/log2timeline or a spreadsheet.

11. Findings

1. Scores and the disqualification flag were changed deliberately, not by system error.
2. The changes came from a single authenticated admin session belonging to the event director's account.
3. No technical indicators of external intrusion were found.
4. Her workstation shows planning and later deletion activity consistent with premeditation.
5. The incident report was not supported by technical evidence, and the reporter was the person with the most direct access.
6. *Wording note:* the report should say the evidence is "consistent with" and "strongly indicates," and leave the final determination of guilt to the court.

12. Legal and Ethical Considerations

- Conflict of interest: the person reporting the incident must not lead the investigation. The sponsors correctly appointed an independent examiner.
- Admissibility: electronic records need an authenticity certificate under Section 63 of the Bharatiya Sakshya Adhiniyam, 2023 (which replaced Section 65B of the Indian Evidence Act). Hash records and chain of custody support this.
- Relevant offences (indicative): unauthorized access and data tampering under the IT Act, 2000 (for example, Sections 43 and 66), and forgery/cheating provisions under the Bharatiya Nyaya Sanhita, 2023. Verify exact sections against your course notes.
- Privacy: examine only data relevant to the incident on the personal laptop and limit disclosure.

13. Challenges and Limitations

- Logs are only as trustworthy as their protection. An admin with server access could have edited them, so remote or write-once log storage is important.

- Attribution to an account is not the same as attribution to a person; physical presence evidence (E8) supports it.
- Deleted-file recovery is not guaranteed.

14. Recommendations

- Enforce role separation, so no single person can both change scores and approve results.
- Require two-person approval for score and disqualification changes.
- Send logs to a remote, tamper-resistant log server in real time.
- Alert on out-of-process admin changes near deadlines.
- Use an independent party to investigate incidents involving management.

15. Conclusion

The investigation shows that the apparent external attack was, on the evidence, an insider action carried out through a legitimate privileged account. Differential database analysis, access-log review, session correlation, and workstation artifacts all point to the same account and device, while the external-attacker hypotheses are not supported. The case shows why independent investigation, careful evidence handling, and corroboration across sources are essential in insider-threat cases.

CASE STUDY 2

SERIAL KEYLESS-ENTRY CAR THEFT INVESTIGATION ("THE ROADSTER BANDIT")

1. Introduction

Modern cars use passive keyless entry: the car unlocks when the fob is "near." Thieves use relay devices to extend the fob's signal, so no glass is broken and no alarm sounds. The evidence is therefore digital: CCTV, gate logs, vehicle telematics, a seized device, and a phone. This case study shows how these sources are collected and correlated to link a suspect to the thefts.

2. Scenario Background

Between 10 and 14 June 2026, four "Aurion X7" SUVs were stolen at night from basement parking lots, with no forced entry. Owners confirmed their fobs were inside their homes. A known thief, **Rishi Rao**, is suspected; his earlier thefts involved leaving a note ("Thanks for the ride") in the car. On 15 June, one SUV was recovered near an industrial yard with such a note inside. A suspected relay device and a Samsung phone were seized from the suspect's room.

3. Assumptions

- All times are IST; the CCTV recorder's clock offset is measured and corrected.
- CCTV footage is retained for at least 7 days.
- Lawful authority exists for the phone, device, and vehicle data.
- Names, plates, and identifiers are fictional; results are *expected* outcomes, not actual execution.

4. Evidence Identified

ID	Evidence	Relevance
E1	CCTV from parking lots	People and vehicle movement
E2	Gate log GATE-LOG-03	Exit time, pass records
E3	ANPR and toll records	Route of the stolen SUV
E4	SUV telematics and infotainment	Unlock, start, GPS, Bluetooth pairing
E5	Seized relay device	Method of attack
E6	Suspect's Samsung phone	Location, photos, Bluetooth, chats
E7	Owner's fob/app log	Proof fob stayed at home
E8	Note found in SUV	Links the thefts

5. Acquisition and Chain of Custody

- **CCTV:** export the native recording with metadata, record the DVR time against a reference clock, and hash it (SHA-256).
- **Phone:** keep it in a Faraday bag, perform a full file-system extraction (e.g., Cellebrite UFED), and hash the extraction.
- **Relay device:** photograph, seal, and document it before any examination.
- **Vehicle:** read logs through the diagnostic interface in read-only mode.
- Every transfer is logged on a custody form (who, when, seal or hash value). Analysis uses verified copies only.

6. Examination and Analysis

Evidence	Procedure	Expected finding	Interpretation
CCTV (E1)	Frame-by-frame review; correct time offset; check metadata	Two people enter at 02:03 AM; one holds a device near the lift lobby, one stands by the SUV; car exits at 02:14 AM	Matches a two-person relay attack; faces may be hidden, so it supports method and timing
Gate log (E2)	Extract incident-window entries	Exit event at 02:14 AM with no valid card scan	Independently confirms the timeline
ANPR/toll (E3)	Search plate on likely routes	Plate seen at two junctions and a toll gate heading to the industrial area	Shows a deliberate route to a drop point
Telematics (E4, E7)	Read unlock, ignition, GPS, and Bluetooth records	Passive-entry unlock at 02:12 AM while the owner's fob is at home; a new Bluetooth pairing "Rishi's S23"	Supports relay entry; the Bluetooth MAC address is an identifier
Relay device (E5)	Document hardware and identify frequency bands	Transmitter/receiver pair suited to the fob's bands	Shows capability, but not use on a specific theft
Suspect's phone (E6)	Parse Bluetooth, location, photo EXIF, chats	MAC matches the SUV pairing; location near the complex 01:50 to 02:20 AM; photo of the SUV dashboard; chat about "Aurion parts"	Strongest link between suspect and vehicle

Evidence	Procedure	Expected finding	Interpretation
Note (E8)	Compare with earlier notes	Same wording and style	Links the four thefts (supporting evidence)

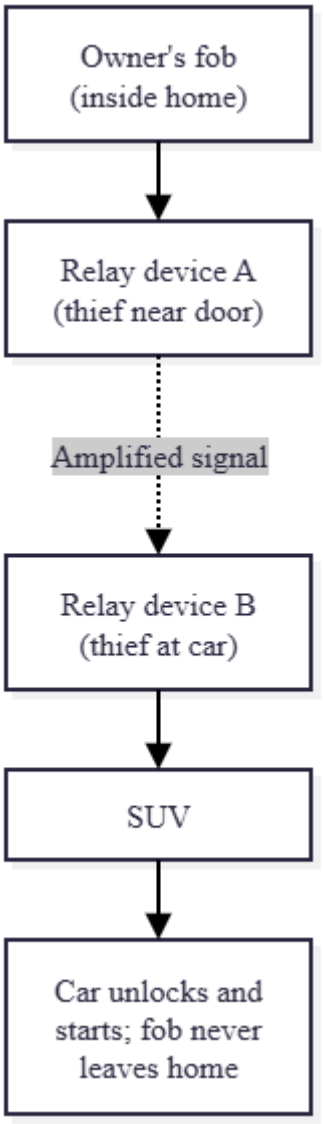
Alternative hypotheses tested:

- *Fob left in car or key cloned:* the app log shows the fob at home, and there is no key-programming event.
- *Phone carried by someone else:* photos, SIM, and chats tie it to the suspect.
- *Coincidental Bluetooth match:* the MAC address and pairing time match exactly.

7. Timeline

Time (IST)	Event	Source
01:50 AM	Suspect's phone near the complex	E6
02:03 AM	Two people enter the basement	E1
02:12 AM	SUV unlocks while the fob is at home	E4, E7
02:14 AM	Engine starts; exit with no valid scan	E4, E2
02:20 AM	SUV seen by ANPR heading to the industrial area	E3

8. Relay Attack and Evidence Map



9. Findings

1. The cars were opened and started by a relay-type attack with no forced entry.
2. CCTV, gate, ANPR, and telematics agree on the timeline.
3. The Bluetooth pairing in the SUV matches the suspect’s phone.
4. Phone location, photos, and chats place the suspect at the scene.
5. The device and the signature note link the four thefts.

10. Legal Considerations

Electronic records need a certificate under Section 63 of the Bharatiya Sakshya Adhiniyam, 2023, supported by hashes and custody records. Indicative offences are theft and theft of a means of transportation under the Bharatiya Nyaya Sanhita, 2023 (verify exact sections with your course notes). Phone extraction needs lawful authority, and unrelated personal data should not be disclosed.

11. Limitations and Recommendations

Limitations: CCTV may be low quality, DVR clocks drift, Bluetooth names can be changed, and vehicle logs may be proprietary. **Recommendations:** use signal-blocking pouches for fobs, add PIN-to-drive, synchronize CCTV clocks with remote backup, and enable ANPR alerts.

12. Conclusion

The thefts were consistent with relay-attack entry. CCTV, gate logs, ANPR, vehicle telematics, and the suspect's phone agree on one timeline and method, and the Bluetooth pairing recorded in the SUV links the suspect to the vehicle. This shows why correlating independent sources under a documented chain of custody builds a reliable case.

CASE STUDY 3
GASLIGHTING THROUGH SOCIAL MEDIA CONTENT MANIPULATION (“YOU NEVER SAID THAT”)

1. Introduction

Gaslighting online is a form of emotional manipulation in which a person is made to doubt her own memory and judgment. Perpetrators edit screenshots, delete posts, and use fake accounts to “confirm” events that never happened. Digital forensics can separate genuine content from fabricated content by examining metadata, device data, and platform records. This case study applies that process to a harassment case on social media.

2. Scenario Background

Ananya, a final-year college student, began noticing that posts she remembered writing disappeared from her profile. Classmates then circulated screenshots showing “her” abusive comments about a faculty member, and several accounts claimed to have “seen her post it.” A group chat insisted she had said things she denies, and her mental well-being and reputation suffered. She reported the matter to the college cyber cell. A former friend, **Dev Malhotra**, is suspected, and his laptop was seized with consent and legal authority.

3. Assumptions

- Ananya consents to examination of her phone and accounts.
- The platform responds to a lawful data request with login IP addresses, device information, and account creation details.
- Her phone had automatic backups enabled.
- Names and identifiers are fictional; results are *expected* outcomes, not actual execution.

4. Evidence Identified

ID	Evidence	Relevance
E1	Victim's Android phone (full extraction)	Original posts, deleted-content traces, app data
E2	Circulated screenshots (original files)	Authenticity and editing analysis
E3	Platform account records	Login IPs, device IDs, deletion history
E4	Fake "witness" accounts	Creation data and activity patterns
E5	Suspect's laptop (disk image)	Editing tools, drafts, account logins
E6	Cloud backup of the victim's phone	Proof of what she actually posted

5. Acquisition and Chain of Custody

- Phone: isolate with airplane mode or a Faraday bag, perform a full file-system extraction, and hash it (SHA-256).
- Screenshots: collect the *original image files* from recipients, not forwarded copies, because forwarding strips metadata.
- Laptop: image through a write-blocker (E01 format) and verify the hash.
- Online content: capture pages with date, URL, and hash, and send preservation requests to the platform before data is deleted.
- Log every transfer on a custody form (who, when, seal or hash). Work only on verified copies.

6. Examination and Analysis

Evidence	Procedure	Expected finding	Interpretation
Phone and cloud backup (E1, E6)	Parse app databases, check backup history and deleted-record traces	No record of the "abusive" posts; the missing posts were deleted from the account by a login at 11:42 PM, not from her phone	The posts she remembers were real, and the deletion did not come from her device
Screenshots (E2)	Inspect metadata (ExifTool), error level analysis, font and spacing checks	Created in an image editor; inconsistent fonts; no screen-capture software tag	Screenshots are fabricated or edited, not genuine captures
Platform records (E3)	Review login history	Deletion session came from an unfamiliar IP and device, not hers	Her account was accessed or her content removed by another party
Fake accounts (E4)	Compare creation times, IPs, device fingerprints, writing style	Accounts created within one week and share one device ID	Same operator, so the "witnesses" are not independent
Suspect's laptop (E5)	Autopsy review of recent files, browser history, saved sessions, deleted files	Image-editing software with edited drafts matching the screenshots; saved logins to the fake accounts	Links the suspect to creating the fabricated content

Alternative hypotheses tested:

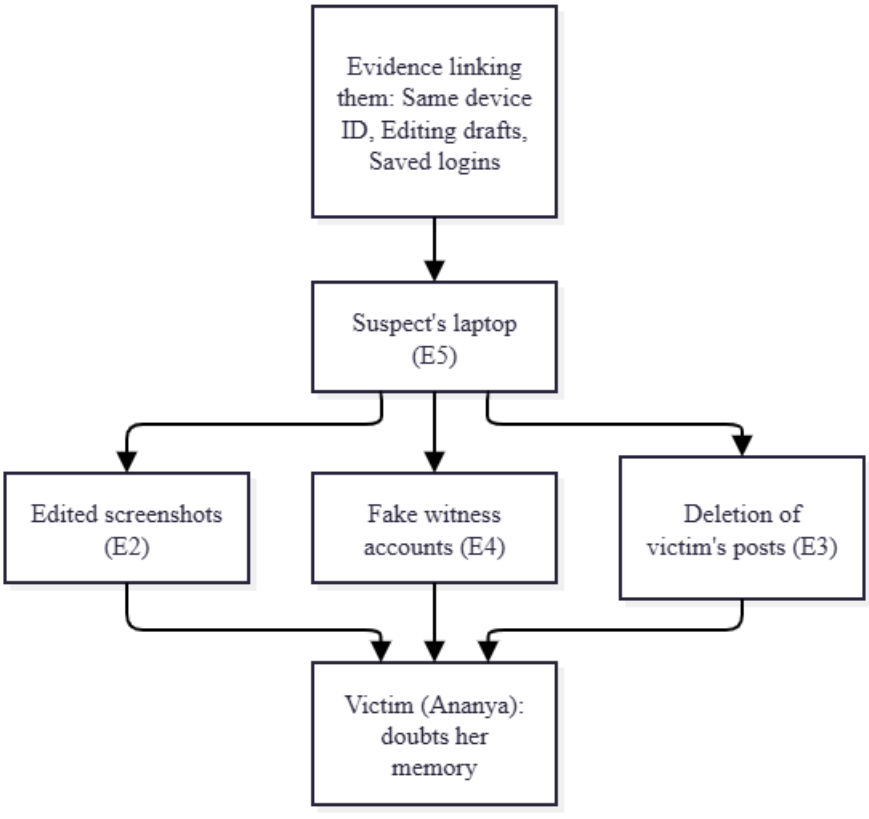
- *Victim deleted the posts herself:* the backup and phone show no such action.

- *Screenshots are genuine:* the metadata and editing traces show they were modified.
- *Shared device or network:* the device ID and drafts point to one specific laptop.

7. Timeline

Time (IST)	Event	Source
Day 1	Fake accounts created	E4
Day 5, 11:42 PM	Victim's posts deleted from an unfamiliar device	E3
Day 6	Edited screenshots created on suspect's laptop	E5
Day 7	Screenshots shared in the group chat; "witnesses" confirm	E2, E4

8. Attribution Map of the Gaslighting Campaign



9. Findings

1. The “abusive posts” were fabricated, and the screenshots show editing traces.
2. The victim’s genuine posts were deleted from an unfamiliar device, not hers.
3. The “witness” accounts share one operator and are not independent.
4. Drafts, tools, and saved logins on the suspect’s laptop link him to the content.
5. The pattern is consistent with a deliberate gaslighting campaign.

10. Legal Considerations

Electronic records need a certificate under Section 63 of the Bharatiya Sakshya Adhiniyam, 2023, supported by hashes and custody records. Indicative offences are identity-related and impersonation offences under the IT Act, 2000 (for example, Sections 66C and 66D) and defamation, forgery, and harassment provisions under the Bharatiya Nyaya Sanhita, 2023. Verify exact sections against your course notes. Examination must respect the victim’s privacy and limit disclosure of her personal data.

11. Limitations and Recommendations

Limitations: the platform may retain data only for a limited time, VPNs can hide IP addresses, and metadata may be stripped by messaging apps. Attribution to a device is not attribution to a person.
Recommendations: enable two-factor authentication, take dated archives of important posts, report fake accounts early, and offer counselling support to the victim alongside the investigation.

12. Conclusion

The evidence indicates a deliberate campaign to make the victim doubt her own memory, using edited screenshots, deleted posts, and coordinated fake accounts.

CASE STUDY 4
EMOTIONAL MANIPULATION THROUGH VOICE AND PROFILE IMPERSONATION(“MOM, IT’S ME”)

1. Introduction

Impersonation scams exploit emotion rather than technology alone. The attacker copies a trusted person’s profile photo and voice, then creates urgency (“I’m in trouble, send money now”) so the victim acts before thinking. Digital forensics can show that the profile and voice are not genuine, trace the money, and link the identity used to a real person. This case study applies the forensic process to such a case.

2. Scenario Background

Mr. Iyer received messages from an unknown number on 8 September 2026, saying “Appa, this is my new number, my phone broke.” The profile photo matched his daughter Divya, who studies abroad. That evening he received a call in a voice that sounded like hers, crying and saying she had been robbed and needed ₹85,000 urgently. He transferred the money by UPI to the account number given. Divya later called him from her real number, unaware of any of this. He reported the fraud to the cyber crime cell the next morning.

3. Assumptions

- Mr. Iyer consents to the examination of his phone, and the call was recorded by his phone’s call recorder.
- The bank, telecom provider, and messaging platform respond to lawful requests.
- Divya provides a clean voice sample and confirms her real phone was not involved.
- Names, numbers, and identifiers are fictional; results are *expected* outcomes, not actual execution.

4. Evidence Identified

ID	Evidence	Relevance
E1	Father's Android phone (full extraction)	Chats, call logs, UPI app data
E2	Call recording and voice notes	Voice authenticity analysis
E3	Cloned messaging profile	Creation details, profile photo origin
E4	UPI and bank transaction records	Money trail and recipient account
E5	Telecom records (CDR) and SIM registration	Number owner, location, device (IMEI)
E6	Daughter's genuine voice sample and phone	Baseline and proof she was uninvolved
E7	Recipient account holder's phone (seized)	Links the account to the operator

5. Acquisition and Chain of Custody

- **Phone:** isolate from the network, perform a full file-system extraction (e.g., Cellebrite UFED), and hash it (SHA-256).
- **Audio:** copy the original recording file without conversion, hash it, and work only on copies.
- **Online content:** capture the cloned profile page with date, URL, and hash, and send a preservation request to the platform.
- **Records:** obtain bank, UPI, and telecom data through formal requests with a signed covering letter.

- Log every transfer on a custody form (who, when, seal or hash). Use verified copies only.

6. Examination and Analysis

Evidence	Procedure	Expected finding	Interpretation
Father's phone (E1)	Parse chats, call logs, UPI history, contact list	First message at 6:12 PM from an unsaved number; call at 7:05 PM; UPI payment at 7:20 PM	Establishes the sequence, with money sent minutes after the call
Voice recording (E2, E6)	Spectrogram review in Audacity or Praat; compare with Divya's real sample	Unnatural pitch consistency, missing breath noises, abrupt cuts, background noise that repeats	Features consistent with synthesized or cloned speech, not conclusive on its own
Cloned profile (E3)	Review creation date, photo source via reverse image search	Account created 3 days earlier; photo copied from Divya's public profile	Impersonation by profile copying
UPI and bank trail (E4)	Trace the transaction ID to the recipient account and onward transfers	Money moved within 40 minutes through two accounts, then withdrawn	A mule-account chain meant to hide the final recipient
SIM and CDR (E5)	Check KYC records, tower locations, IMEI	SIM issued on a forged ID; handset IMEI also used with another SIM	The SIM is a disposable identity, but the IMEI links the device to a person

Evidence	Procedure	Expected finding	Interpretation
Account holder's phone (E7)	Extract chats, contacts, app data	Chats with the operator about "split of the amount" and the same cloned photo saved	Connects the mule account to the scam

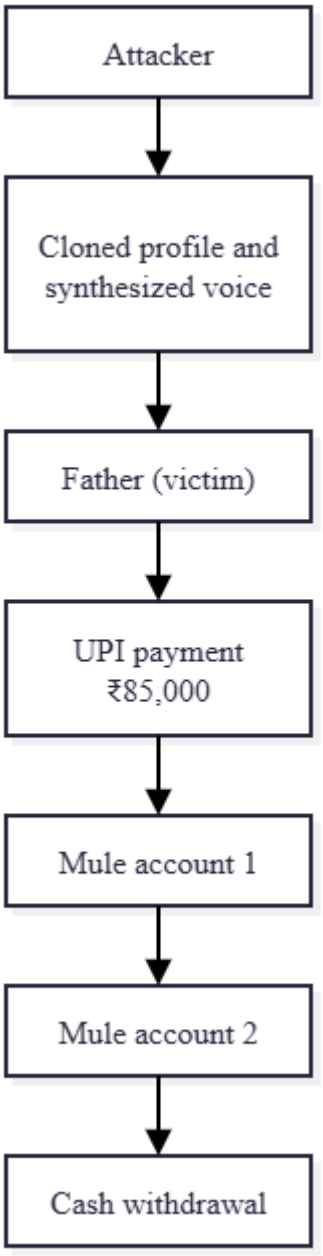
Alternative hypotheses tested:

- *Divya involved:* her phone logs and location show no involvement.
- *Genuine call from a friend's phone:* the number and profile were created for the scam, and the voice shows synthesis traces.

7. Timeline

Time (IST)	Event	Source
5 Sep	Cloned profile created	E3
8 Sep, 6:12 PM	"New number" message sent	E1
8 Sep, 7:05 PM	Distress call, voice synthesized	E1, E2
8 Sep, 7:20 PM	₹85,000 sent by UPI	E4
8 Sep, 8:00 PM	Funds moved to second account and withdrawn	E4

8. Impersonation Attack and Money Trail



9. Findings

1. The “daughter” profile was cloned, and the profile photo was copied from her public account.
2. The voice shows features consistent with synthesis and does not match the genuine sample.
3. The SIM was issued on forged documents, but the handset IMEI connects it to another identity.

4. Money was routed through mule accounts within 40 minutes, a typical layering pattern.
5. Chats on the account holder's phone link the account to the operator.

10. Legal Considerations

Electronic records need a certificate under Section 63 of the Bharatiya Sakshya Adhiniyam, 2023, supported by hashes and custody records. Indicative offences are identity theft and cheating by impersonation under the IT Act, 2000 (Sections 66C and 66D), and cheating and forgery provisions under the Bharatiya Nyaya Sanhita, 2023. Verify exact sections against your course notes. Prompt reporting matters because banks can freeze funds quickly, and the victim's financial details should be handled confidentially.

11. Limitations and Recommendations

Limitations: voice synthesis detection is not definitive and improves constantly, messaging apps hide metadata, and mule accounts may belong to people who were themselves deceived.

Recommendations: verify urgent requests by calling the person on their known number, agree on a family code word, report fraud quickly (the golden hour for freezing funds), limit public sharing of photos and voice clips, and enable UPI limits and alerts.

12. Conclusion

The evidence indicates a planned impersonation, built on a copied profile, a synthesized voice, a forged SIM, and a chain of mule accounts. Phone data, audio analysis, bank records, and telecom records agree on one sequence and contradict the idea that the contact was genuine. The case shows that emotional manipulation succeeds by creating urgency, and that forensic work can rebuild the trail and help recover funds.

CASE STUDY 5
INSIDER PRIVILEGE ESCALATION AND DATA EXFILTRATION (“THE QUIET ADMIN”)

1. Introduction

Insider threats are hard to detect because the person already has legitimate access. The attacker here is not breaking in; he is quietly widening what he is allowed to do. Digital forensics can separate normal helpdesk activity from privilege abuse by reading logs, examining memory, and rebuilding a timeline. This case study applies the forensic process to an insider privilege escalation and data theft.

2. Scenario Background

Karthik, a junior IT support engineer at SwiftLine Logistics, had only basic helpdesk rights (password resets, workstation support). On 30 September 2026 the SIEM flagged a large after-hours VPN session and an unusual archive on the billing file server. Review showed that on 15 September, at 1:47 AM, his account had been added to the privileged group “Billing-Admins”. This happened minutes after ticket INC-4471 (“routine maintenance, group cleanup”) was closed. The ticket had been opened and closed by Karthik himself, with no approver. Over the next two weeks, customer shipment and billing records were copied out. HR and the security team preserved evidence the same day.

3. Assumptions

- SwiftLine consents to the examination and has enabled advanced audit policy, Sysmon, and VPN logging.
- Logs were forwarded to a central SIEM, and the domain controller clocks were synchronized by NTP.
- Karthik’s workstation was powered on when seized, so a memory image could be taken.
- Names, IDs, addresses, and times are fictional; results are expected outcomes, not actual execution.

4. Evidence Identified

ID	Evidence	Relevance
E1	Windows Security event logs (domain controller and file server)	Logons, group changes, privilege use
E2	Active Directory audit records and ticketing system export	Who changed which group, and ticket INC-4471 history
E3	Sysmon logs from Karthik's workstation	Process creation, network connections, file creation
E4	Memory image of Karthik's workstation	Running processes, command lines, network sockets, credentials in memory
E5	VPN gateway logs	Remote logins, source IP, session duration, data volume
E6	File server access logs (object access)	Which customer and billing files were read or copied
E7	Cloud storage and email gateway logs	Destination of exported data

5. Acquisition and Chain of Custody

- **Memory first:** capture the workstation RAM with a trusted tool (e.g., FTK Imager or WinPmem) before shutdown, then hash it (SHA-256). Volatile data is lost on power-off.
- **Disk:** after memory capture, take a forensic image through a write blocker and hash it.

- **Logs:** export the Security, Sysmon, and AD logs in native .evtx format from the domain controller and file server. Export SIEM and VPN logs with their original timestamps. Hash all exports and preserve copies read-only.
- **Records:** obtain the ticketing system history, HR access records, and cloud logs through formal requests with a signed covering letter.
- Log every transfer on a custody form (who, when, seal or hash). Analyze only verified copies.

6. Examination and Analysis

Evidence	Procedure	Expected finding	Interpretation
Security logs (E1)	Filter for Event IDs 4728/4732/4756 (group member added), 4672 (special privileges), 4624 (logon), 4688 (process creation)	4728 on 15 Sep at 1:47 AM adding Karthik's account to Billing-Admins, performed from his workstation using a service account	Privilege escalation by group modification
AD audit and tickets (E2)	Compare change time with ticket history	INC-4471 opened and closed by Karthik at 1:41 AM; no approver; group change 6 minutes later	The "maintenance" ticket was used as cover for the change
Sysmon (E3)	Review Event IDs 1 (process), 3	PowerShell with encoded commands, net	Reconnaissance, staging, and

	(network), 11 (file create)	group and whoami /priv commands, 7-Zip creating an archive, upload to a cloud storage domain	exfiltration activity
Memory image (E4)	Volatility 3: windows.pslist, cmdline, netscan, malfind	PowerShell and 7-Zip processes with command lines referencing billing shares; an active connection to the cloud host; service account credentials present in process memory	Links the actions to Karthik's live session and shows how the service account was reached
VPN logs (E5)	Match session times with access events	Sessions between 1:30 and 3:10 AM on three nights from the same home IP, the last transferring about 1.8 GB	Remote after-hours access consistent with data export
File access logs (E6)	Event ID 4663 on billing and shipment shares	Thousands of reads of customer and billing files by his	Bulk collection that is outside his role

		account within 90 minutes	
Cloud and email logs (E7)	Trace upload destination and account	Archive uploaded to a personal cloud account registered with his phone number	Links the destination to the person

Alternative hypotheses tested:

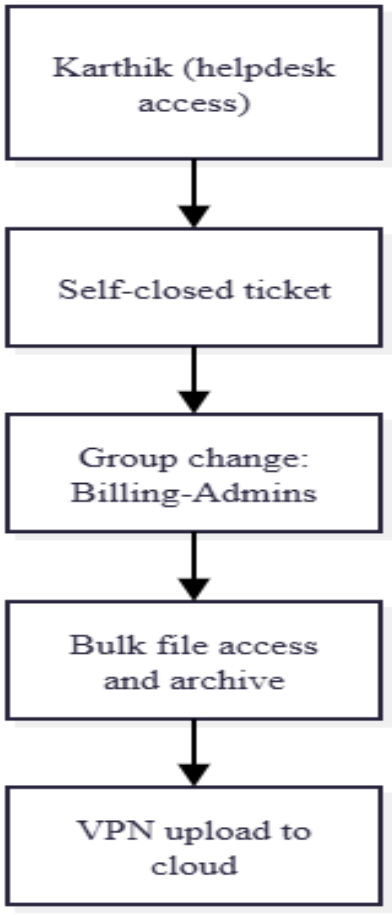
- Legitimate maintenance: no approved change request, the ticket was self-closed, and the group is unrelated to helpdesk duties.
- Stolen credentials used by someone else: the activity came from his workstation (memory and Sysmon), his home IP, and his assigned VPN profile.
- Colleague using his session: badge records show him present, and the same pattern repeated across several nights.
- Log tampering: no Event ID 1102 (log cleared) was found, and SIEM copies match the originals.

7. Timeline

Time (IST)	Event	Source
2 Sep	Reconnaissance commands (net group, whoami /priv) begin	E3
14 Sep	Ticket INC-4471 raised by Karthik	E2
15 Sep, 1:41 AM	Ticket closed by Karthik, no approver	E2

Time (IST)	Event	Source
15 Sep, 1:47 AM	Account added to Billing-Admins	E1, E2
22 Sep, 2:10 AM	First bulk read of billing files	E6
28 Sep, 1:30 to 3:10 AM	VPN session, archive created and uploaded (about 1.8 GB)	E3, E5, E7
30 Sep	SIEM alert; evidence preserved	E1
1 Oct	Workstation memory image acquired	E4

8. Insider Privilege Escalation and Data Exfiltration



9. Findings

- The privilege escalation was deliberate: Karthik's account was added to Billing-Admins minutes after a ticket he opened and closed himself.
- The change was made at 1:47 AM using a service account reached from his workstation.
- Sysmon and memory evidence indicate reconnaissance, archiving, and upload activity from his session.
- VPN, file access, and cloud logs indicate about 1.8 GB of customer and billing data left the network.
- The clean log chain and matching SIEM copies indicate no tampering with the records.
- Use wording such as "consistent with" and "indicates"; guilt is for the court to decide.

10. Legal Considerations

Electronic records need a certificate under Section 63 of the Bharatiya Sakshya Adhiniyam, 2023, supported by hashes and custody records. Indicative offences are unauthorized access and data theft under the IT Act, 2000 (Sections 43, 66, and 72), and breach of trust and related provisions under the Bharatiya Nyaya Sanhita, 2023. Personal data duties under the Digital Personal Data Protection Act, 2023 may also apply. Verify exact sections against your course notes. Employee monitoring should follow company policy, and customer data must be handled confidentially.

11. Limitations and Recommendations

Limitations: memory capture may miss short-lived processes, logs depend on audit policies being enabled beforehand, encrypted uploads hide content, and a service account may mask who really used it without supporting evidence. **Recommendations:** enforce least privilege and separation of duties (no self-approval of tickets), alert on any privileged group change, require approved

change requests, use just-in-time admin access, monitor after-hours VPN and bulk file access, protect service account credentials, and forward logs to a central, tamper-resistant store.

12. Conclusion

The evidence indicates a planned insider escalation, built on a self-closed ticket, a privileged group change at an odd hour, a staged archive, and a remote upload. Event logs, Sysmon records, memory analysis, and VPN data agree on one sequence and contradict the idea of routine maintenance. The case shows that insiders succeed when approvals and monitoring are weak, and that log and memory forensics can rebuild the trail and support action.